بسمه تعالی



تشخیص نفوذ
معرفی درس



جهاد فقط در میدان جنگ نیست
در میدان علم هم مثل بقیه‌ی میادین زندگی، جهاد لازم است

بیانات رهبر شهید در سال 87

مجاهد فی سبیل‌الله تولید کننده است
باید هم علم را بیاموزیم و هم علم را تولید کنیم
ما باید یک کشور عالم بشویم

بیانات رهبر شهید در سال 85

چرا تشخیص نفوذ؟

آغاز درس با یک مثال غیرسیاسی ☺

خرداد ۸۴
به دنیا اومده
بودید؟!









بیست خرداد
۹۲

هشت سال، یعنی تقریبا چقدر زمان؟

آغاز درس با یک مثال غیرسیاسی ☺

خرداد ۸۴
به دنیا اومده
بودید؟!









بیست خرداد
۹۲

✓ دقیقا در همین مدت یعنی از سال ۲۰۰۶ تا ۲۰۱۴، یک گروه APT چینی در آمریکا فعال بود تا اینکه در سال ۲۰۱۴ توسط شرکت Mandiant رسما گزارش شد!(گرچه از مدتی قبل شناخته شده بود) و مشخص گردید صدها ترابایت داده از بیش از ۱۴۰ سازمان آمریکایی همزمان در طول این مدت دزدیده شده است.

✓ تنها یکی از این نهادها Lockhead Martine بود!

جان چمبرز (مدیرعامل سابق سیسکو) آن را صورت‌بندی کرده است:
« در دنیا فقط دو دسته سازمان وجود دارند: آن‌هایی که هک شده‌اند، و آن‌هایی که هک شده‌اند اما هنوز خودشان نمی‌دانند!

فلسفه کلی درس

“Prevention is ideal, but detection is a must”

چرا تشخیص؟؟

- **۱) افزایش تصاعدی «زمان ماندگاری» (Dwell Time)** طبق گزارش معتبر **Mandiant M-Trends**: میانگین جهانی ماندگاری مهاجم در شبکه تا پیش از کشف (Dwell Time) در سال‌های اخیر بین **۱۰ تا ۲۰ روز** (و در گذشته بیش از ۲۰۰ روز!) بوده است. اگر تشخیص ندهید، مهاجم هفته‌ها یا ماه‌ها مهمان خاموش شماست. در این مدت، او شبکه را نقشه‌برداری می‌کند، دسترسی‌های ادمین می‌سازد، بکاپ‌ها را شناسایی و پاک می‌کند، و تمام سورس‌کدها یا اطلاعات مشتریان را سرقت می‌کند.
- **۲) تبدیل یک رخنه ساده به یک فاجعه کامل:** بین نفوذ اولیه تا تخریب نهایی یک فاصله زمانی حیاتی وجود دارد:
- **با تشخیص:** یک کارمند روی لینک بدافزار کلیک می‌کند ،سیستم EDR/XDR در دقیقه اول آن پروسه را شناسایی و سیستم را ایزوله می‌کند ،**نتیجه یک حادثه مهارشده بدون خسارت مالی می شود.**
- **بدون تشخیص:** بدافزار اجرا می‌شود ،مهاجم به سرورهای اکتیو دایرکتوری نفوذ می‌کند ،باج‌افزار در تمام دیتاسنتر پخش می‌شود ،**نتیجه یک فاجعه کامل کسب‌وکار و میلیاردها تومان/دلار خسارت.**
- **۳) باج‌خواهی دوگانه و سه‌گانه (Double/Triple Extortion)**رامروزه باج‌افزارها فقط اطلاعات را رمز نمی‌کنند؛ ابتدا چند ده گیگابایت اطلاعات حساس را می‌دزدند. اگر تشخیص ندهید، روزی می‌رسد که نه دیتایی دارید، نه داده پشتیبانی، و مهاجم تهدید می‌کند که قراردادها، اطلاعات هویتی و اسناد محرمانه شما را روی اینترنت منتشر خواهد کرد.
- **۴) بی‌آبرویی عمومی: «دیگران نفوذ را به شما خبر می‌دهند!»**ربدترین سناریو برای یک مدیر امنیت این است که خودش نفوذ را کشف نکند:رمشتریانتان زنگ بزنند و بگویند کارت‌های بانکی‌شان خالی شده؛رپلیس فتا یا اف‌بی‌آی تماس بگیرد و بگوید سرورهای شما در حال حمله به زیرساخت دیگری هستند؛ریا خبرنگاران در شبکه‌های اجتماعی اسناد دیتابیس شما را برای دانلود بگذارند!
- **۵) ضربه مالی و مرگ تجاری شرکت‌ها:** طبق آمار **Cybersecurity Ventures** و گزارش‌های **IBM**: ۶۰ درصد از شرکت‌های کوچک و متوسط ظرف ۶ ماه پس از یک حمله و نقض داده شدید که کشف‌نشده باقی مانده بود، **ورشکست و تعطیل می‌شوند**

تشخیص نفوذ در وضعیت فعلی چقدر طول می کشد؟

به نظر شما چقدر طول می کشد؟

به نظرتون در سالهای جدیدتر این عدد چه تغییری کرده ؟

تشخیص نفوذ در وضعیت فعلی چقدر طول می کشد؟

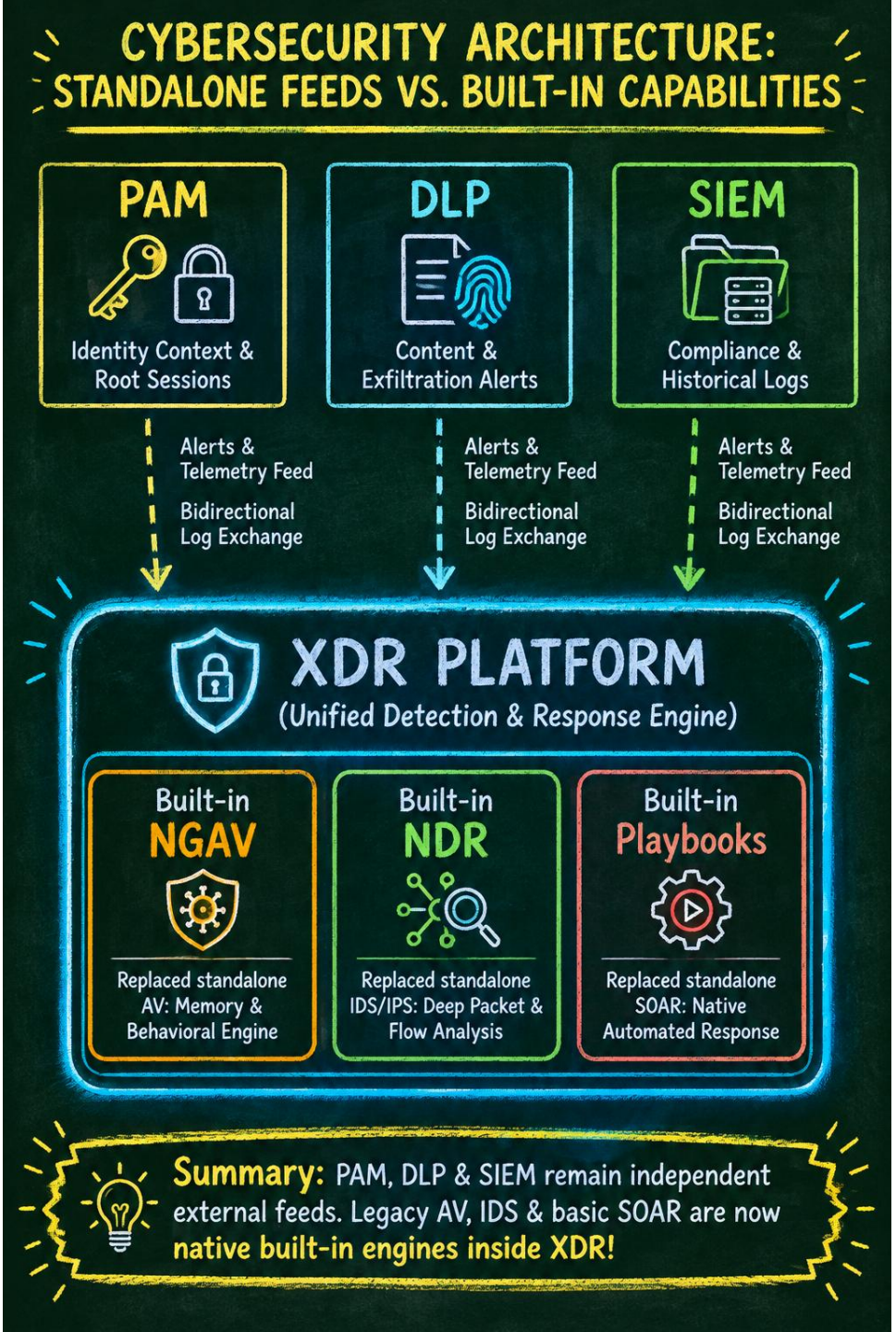
IBMاظهار می‌کند که به طور متوسط، کشف یک نقض امنیتی در سال ۲۰۲۲، ۲۰۷ روز و مهار مؤثر آن، ۷۰ روز دیگر طول کشیده است. این میزان زمان صرف شده به این معنی است که میانگین زمان برای رسیدگی کامل به یک نقض امنیتی در سال ۲۰۲۲، ۲۷۷ روز بوده است.

تشخیص نفوذ در وضعیت فعلی چقدر طول می کشد؟

- IBMاظهار می‌کند که به طور متوسط، کشف یک نقض امنیتی در سال ۲۰۲۲، ۲۰۷ روز و مهار مؤثر آن، ۷۰ روز دیگر طول کشیده است. این میزان زمان صرف شده به این معنی است که میانگین زمان برای رسیدگی کامل به یک نقض امنیتی در سال ۲۰۲۲، ۲۷۷ روز بوده است.
- میانگین کلی جهانی چرخه رخنه (برای همه سازمان‌ها) از **۲۷۷ روز** در سال ۲۰۲۲، با گسترش ابزارهای خودکار به **۲۵۸ روز** و سپس به حدود **۲۴۱ روز** کاهش یافته که پایین‌ترین رکورد در ۷ سال اخیر بوده است.
- هوش مصنوعی همزمان به حمله کننده ها هم کمک می کند!

نام درس با محتوای درس

- نام درس سیستم های تشخیص نفوذ است
- سیستم های تشخیص نفوذ (IDS)و سیستم های پیشگیری از نفوذ (IPS) در گذشته مجزا طراحی می شدند .
- اما در عمل این سیستم ها امروزه در موقعیت های مختلفی با دیگر راهکارهای امنیتی ادغام شده اند و یا تکامل یافته اند.
- در سیستم های انتهایی مفهوم EDR (End-point detection-response) بوجود آمده
- در شبکه هم دیوارهای آتش نسل جدید چنین قابلیت هایی را دارند.
- همچنان تمرکز درس روی مفهوم تشخیص نفوذ است اما هم پوشانی با بقیه مفاهیم دیده می شود.



نام درس با محتوای درس

- **PAM (Privileged Access Management**مدیریت دسترسی‌های ویژه: گذرواژه‌ها، نشستها و دسترسی‌های کاربران با سطح دسترسی بالا (مانند ادمین‌ها و **Root**) را کنترل، ایمن‌سازی و ضبط می‌کند.
- **DLP (Data Loss Prevention**جلوگیری از نشت داده:محتوای حساس سازمانی را شناسایی کرده و مانع از خروج غیرمجاز (**Exfiltration**) یا انتقال آن به بیرون از شبکه می‌شود.
- **SIEM (Security Information & Event Management**مدیریت اطلاعات و رخدادهای امنیتی: لاگ‌ها و رخدادهای کل زیرساخت را برای تحلیل تاریخی، همبسته‌سازی داده‌ها و انطباق با قوانین (**Compliance**) متمرکز و ذخیره می‌کند.
- **XDR (Extended Detection & Response** – شناسایی و پاسخ گسترده):پلتفرم مرکزی یکپارچه‌ای است که داده‌های نقاط پایانی، شبکه و فضای ابری را ترکیب کرده تا تهدیدات پیچیده را به‌صورت بلادرنگ شناسایی و مهار کند.

- **NGAV (Next-Generation Antivirus** – آنتی‌ویروس نسل جدید / داخلی **XDR**): با تحلیل رفتاری و پایش حافظه (به‌جای تکیه بر امضای ساده)، بدافزارها و حملات بدون فایل (**Fileless**) را در سیستم‌ها مسدود می‌کند.
- **NDR (Network Detection & Response** – شناسایی و پاسخ شبکه / داخلی **XDR**): ترافیک شبکه را از طریق تحلیل عمیق بسته‌ها (**DPI**) و جریان داده‌ها برای شناسایی رفتارهای مشکوک و غیرعادی پایش می‌کند.
- **Built-in Playbooks** (پلی‌بوک‌های خودکار / جایگزین **SOAR** بومی): سناریوهای واکنشی از پیش‌تعریف‌شده را به‌صورت کاملاً خودکار برای مهار فوری تهدیدات (مانند ایزوله کردن سیستم آلوده) اجرا می‌کند

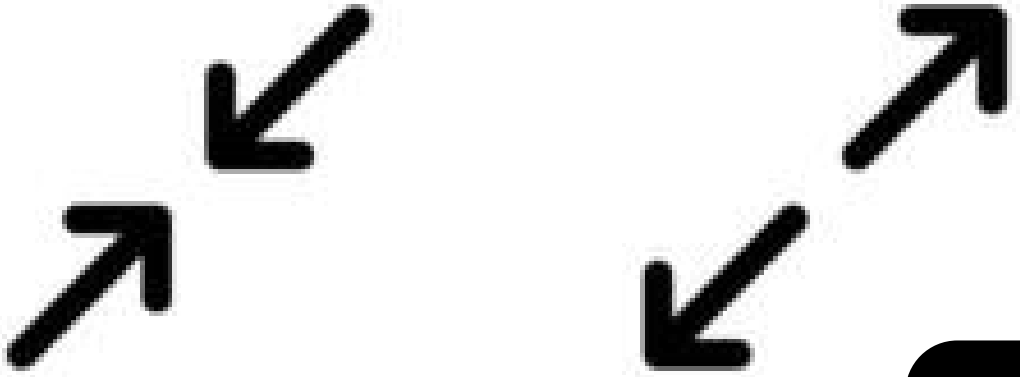
تمرکز درس

- **تمرکز درس روی مفهوم XDR است .**
CrowdStrikeشرکتی که تمام هویتش بر پایه پلتفرم **Falcon (EDR/XDR)**بنا شده، به ارزش بازاری بالغ بر **۶۰ تا ۸۰+ میلیارد دلار** در و درآمد سالانه مکرر ((ARRآن از مرز **۳,۵ تا ۴ میلیارد دلار** عبور کرده است.
- طبق گزارش‌های تحلیلی **Gartner**و **Fortune Business Insights**، بازار جهانی امنیت XDRو EDRبا نرخ رشد سالانه مرکب بیش از **۲۰٪** در حال حرکت به سمت بازاری با ارزش بیش از **۱۰ تا ۱۵ میلیارد دلار** است.



وضعیت فعلی سیستم های تشخیص نفوذ

موضوعات داغ آکادمیک، یکی پس از دیگری، با حجم بالا هر فناوری جدیدی را با سیستم های تشخیص نفوذ ترکیب می کنند و انبوه مقالات در این حوزه تولید می شود.
معمولا نیازهای خطامثبت و منفی صنعتی مراعات نمیشود
یا روی داده های بسته نتایج قابل قبول است



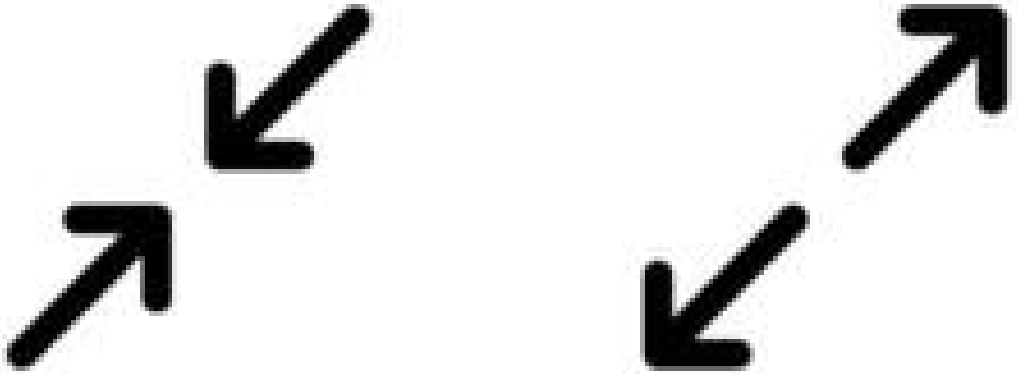
سیستم های سنتی با خطامثبت و خطامنفی غیرقابل قبول

تلاشهای دستی و
پلی بوک های خاص
منظوره توسط
کارشناسان خبره

وضعیت فعلی سیستم های تشخیص نفوذ

موضوعات داغ آکادمیک، یکی پس از دیگری، با حجم بالا هر فناوری جدیدی را با سیستم های تشخیص نفوذ ترکیب می کنند و انبوه مقالات در این حوزه تولید می شود.
معمولا نیازهای خطامثبت و منفی صنعتی مراعات نمیشود یا روی داده های بسته نتایج قابل قبول است

استارتاپ های متعددی با شیب قابل توجه ایده های آکادمیک را به صورت بالغی رسانده و توسط شرکت های غالب بر بازار خریداری می شوند و روش های نوینی که بتوانند به بلوغ برسند وارد خط اصلی محصولات می شوند.

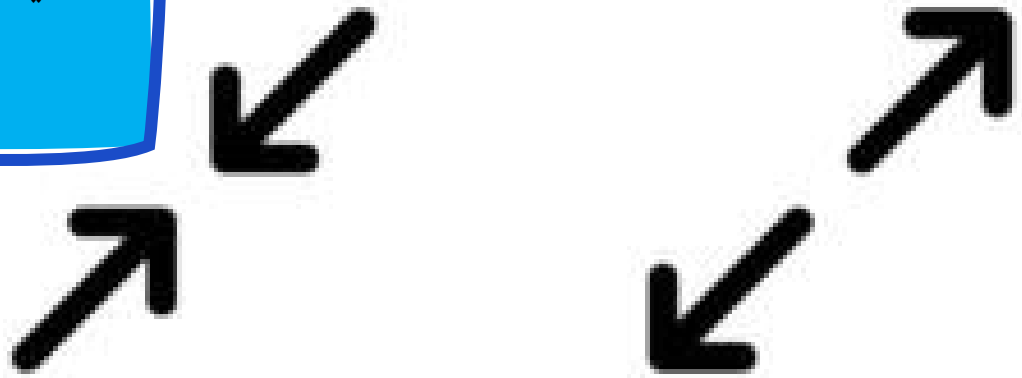


سیستم های سنتی با خطامثبت و خطامنفی غیرقابل قبول

وضعیت فعلی سیستم های تشخیص نفوذ

موضوعات داغ آکادمیک، یکی پس از دیگری، با حجم بالا هر فناوری جدیدی را با سیستم های تشخیص نفوذ ترکیب می کنند و انبوه مقالات در این حوزه تولید می شود.
معمولا نیازهای خطامثبت و منفی صنعتی مراعات نمیشود
یا روی داده های بسته نتایج قابل قبول است

- چند مثال می توانید بزنید از اینکه چرا محصولات فعلی کافی نیستند و چرا مساله چنین محصولاتی را در دانشگاه باید حل کرد ؟
- اساسا تجربه کار با چنین سیستم هایی دارید؟



سیستم های سنتی با خطامثبت و خطامنفی غیرقابل قبول

Direction	Timestamp	Src IP	Dst IP	Port	TLS SNI	Bytes	Note
▶ Client → Server	2025-09-19 10:00:00	10.0.0.5	172.217.0.46	443	www.google.com	680	TLS handshake + request
◀ Server → Client	2025-09-19 10:00:01	172.217.0.46	10.0.0.5	443	www.google.com	4500	TLS encrypted response
▶ Client → Server	2025-09-19 10:00:15	10.0.0.5	172.217.0.46	443	www.google.com	720	TLS handshake + request
◀ Server → Client	2025-09-19 10:00:16	172.217.0.46	10.0.0.5	443	www.google.com	3500	TLS encrypted response
▶ Client → Server	2025-09-19 10:02:30	10.0.0.5	172.217.0.46	443	www.google.com	650	TLS handshake + request
◀ Server → Client	2025-09-19 10:02:31	172.217.0.46	10.0.0.5	443	www.google.com	250	TLS encrypted response

یک مثال از خطامنفی در تشخیص نفوذ در سطح شبکه

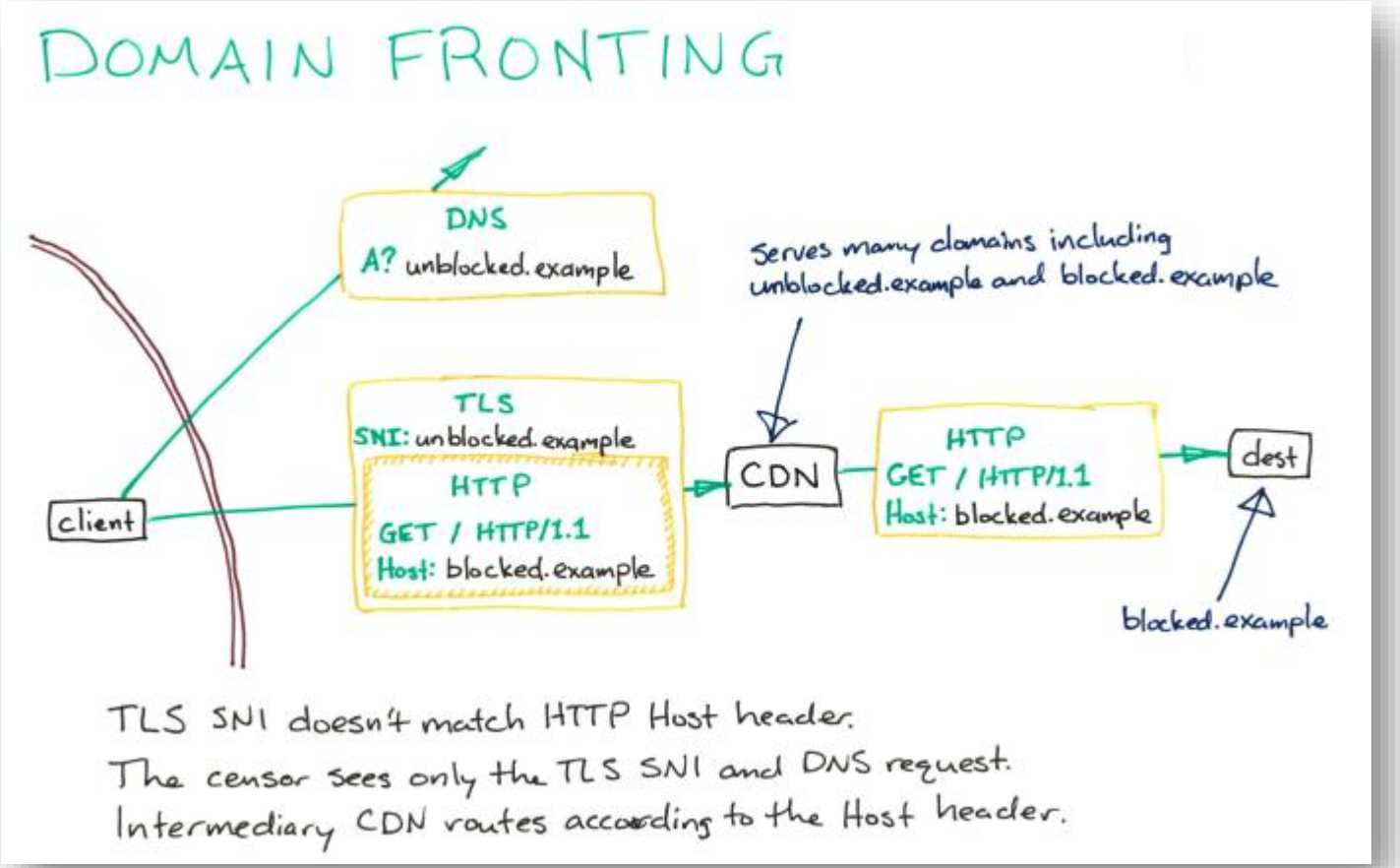
سیستم های تشخیص نفوذ به چیزی مشکوک می شوند؟

شما به عنوان کارشناس امنیتی، به چیزی مشکوک می شدید؟

یک قابلیت مجاز ولی مشکوک

- CDNها طوری طراحی شده اند که بتوانند به دامنه های متعددی در پشت یک ip خدمات بدهند.
  - مثلا شما ممکن است برای دامنه برنامه تحت وب خود که در دامنه گوگل نیست، از گوگل خدمات ابری دریافت کرده باشید و نام دامنه خود را به آن نگاشت داده باشید بنابراین گوگل آدرس های مختلفی دارد در حالی که در گواهی نام دامنه آن فقط گوگل آمده است
- پس یک کارگزار CDN بی توجه به دامنه درخواستی،TLS را خاتمه می دهد و درخواست را به مقصدی که در post آن نوشته شده می فرستند (ترجیحا دوباره رمز می کند)
  - مثل یک هاب پستی عمل می کند.

جلودارسازی دامنه (domain fronting)



- پس حالا که یک مامور پست داریم که بی توجه به همخوانی نام دامنه داده شده در لایه TLS و نام دامنه در داخل درخواست http ، آن را توزیع می کند، می توانیم توسط این مامور مقصد بسته رادر لایه TLS پنهان کنیم و فقط در لایه http (که در داخل تونل است ودیده نمی شود) واقعیت را برای مامور پست افشا کنیم.
- کاربردها:
  - روشی برای دور زدن فیلترهای امنیتی
  - بدافزارها و گروه‌های تهدید پیشرفته از پوشش دامنه برای پنهان کردن نقاط پایانی فرماندهی و کنترل ز مدافعان شبکه استفاده می‌کنند.
  - انتقال قابل اتصال " Tor "meekاز پوشش دامنه برای پنهان کردن ترافیک به عنوان اتصال به ارائه دهندگان اصلی ابر استفاده می‌کند.
  - چارچوب‌های حمله سفارشی (مانند Cobalt Strike)از دامنه‌های پوشش داده شده برای فراخوانی‌های مخفی پشتیبانی می‌کنند.

Direction	Timestamp	Src IP	Dst IP	HTTP Host	Method	URL Path	Status	Req Size	Resp Size
▶ Client → Server	2025-09-19 10:00:00	10.0.0.5	172.217.0.46	www.google.com	GET	/search?q=sec	—	680	—
◀ Server → Client	2025-09-19 10:00:01	172.217.0.46	10.0.0.5	www.google.com	—	—	200	—	4500
▶ Client → Server	2025-09-19 10:00:15	10.0.0.5	172.217.0.46	**malicious.evil.com**	POST	/api/data	—	720	—
◀ Server → Client	2025-09-19 10:00:16	172.217.0.46	10.0.0.5	**malicious.evil.com**	—	—	200	—	3500
▶ Client → Server	2025-09-19 10:02:30	10.0.0.5	172.217.0.46	**malicious.evil.com**	GET	/api/steal	—	650	—
◀ Server → Client	2025-09-19 10:02:31	172.217.0.46	10.0.0.5	**malicious.evil.com**	—	—	404	—	250

واقعیت آنچه اتفاق افتاده بود.

آیا نسخه سیستم عامل/برنامه در حال اجرا دستکاری شده است؟

- اگر بخواهید مطمان شوید که هیچ ویروسی در سیستم عامل یا فایل های شما ننشته است چه می کنید؟

یک مثال از خطامنفی در تشخیص نفوذ در سطح سیستم

- به نظر من در مواردی نظیر آنتی‌ویروس، فایروال، و یا WAF نمی‌توانیم با محصولات خارجی رقابت کنیم. چون این شرکت‌های داخلی partnership ندارند، در نتیجه دسترسی مثلا به کرنل ندارند و در نتیجه بعضا کیفیت مناسب هم نمی‌توانند داشته باشند. از بالا که نگاه می‌کنم واقعا فایروال‌های بومی اصلا نمی‌کشند. یا مثلا متوجه نمی‌شوم که اگر ما داریم ویندوز استفاده می‌کنیم دیگر این‌که آنتی‌ویروس خارجی استفاده نکنیم، چه معنایی دارد.

بخشی از گفت و گوی یکی از شرکتهای خصوصی که قطعا می شناسید!

نظر شما چیه؟

- به نظر من در مواردی نظیر آنتی‌ویروس، فایروال، و یا WAF نمی‌توانیم با محصولات خارجی رقابت کنیم. چون این شرکت‌های داخلی partnership ندارند، در نتیجه دسترسی مثلا به کرنل ندارند و در نتیجه بعضا کیفیت مناسب هم نمی‌توانند داشته باشند. از بالا که نگاه می‌کنم متوجه نمی‌شوم که اگر ما داریم ویندوز استفاده می‌کنیم دیگر این‌که آنتی‌ویروس خارجی استفاده نکنیم، چه معنایی دارد.

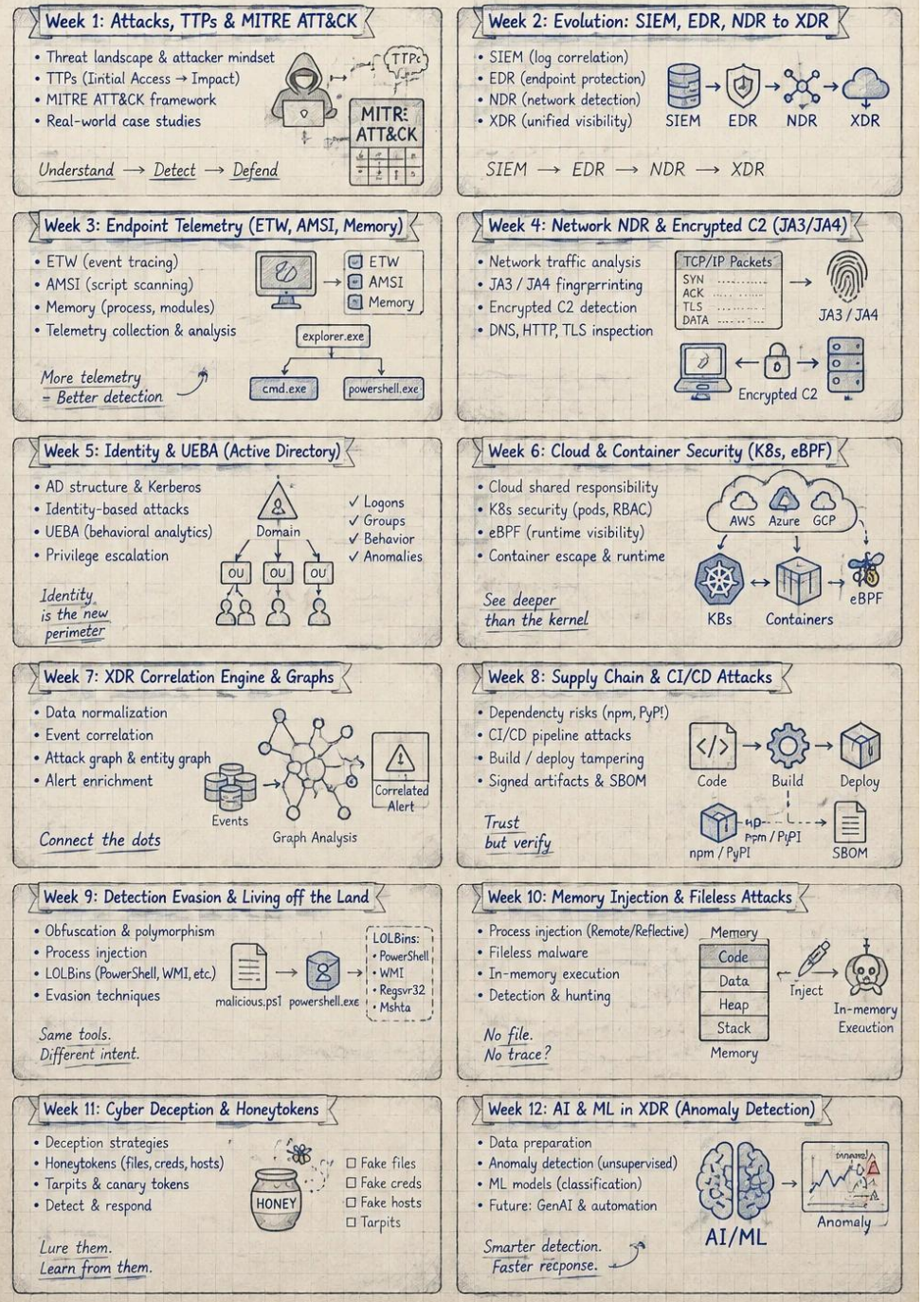
بخشی از گفت و گوی مدیر امنیت یکی از شرکتهای خصوصی که قطعا می شناسید!

تبدیل یک چالش مهارشدنی به یک انتحاری خودخواسته!

- در یک **کشور متخاصم** با خاستگاه ویندوز، این حرف نه‌تنها غیرمنطقی است، بلکه از دید امنیت ملی یک **فاجعه‌ی در سطح دکترین** به شمار می‌رود.
کسانی که چنین گزاره‌ای مطرح می‌کنند حالا که ویندوز داریم، بذار از بقیه محصولات شرکت‌های آمریکایی مثل فایروال، آنتی‌ویروس، EDR و سوئیچ هم استفاده کنیم، دچار یک خطای بنیادین به نام **مغلطه تسلیم مطلق (All-or-Nothing Fallacy)** هستند.
- ویندوز به خودی خود یک سیستم‌عامل است. اگر سیستم‌عامل آفلاین باشد، در شبکه ایزوله قرار گیرد یا پورت‌های تله‌متری آن در فایروال مسدود شود، کارکرد پایه‌ای خود را حفظ می‌کند.اما محصولات امنیتی باید دائماً با ابر خارجی ارتباط داشته باشند تا امضاها و هوش تهدید بگیرند؛سنسورهای پایش بلادرنگ هستند: تمام تحرکات شبکه، هش فایل‌ها، ارتباطات مشکوک و لاگ سرورها به سرورهای ابری ارسال می‌شود.
- در شرایط تخاصم ژئوپلیتیکشرکت‌های فناوری موظف به پیروی از فرامین دولتی خود هستند.اگر بحران نظامی یا امنیتی تشدید شود، سریع‌ترین و بی‌دردسرترین اهرم فشار، قطع سرویس‌های امنیتی و کلود است.
- اگر لایه پلتفرم (سیستم‌عامل) غیرخودی و غیرقابل اعتماد است، لایه‌های نظارتی و بازرسی باید حتماً بومی، متن‌بازِ ممیزی‌شده یا از کشورهای ثالثِ بی‌طرف باشند. یعنی اگر سیستم‌عامل شما ویندوز است، فایروال، IDS، سیستم مانیتورینگ شبکه و سیستم مدیریت دسترسی باید طوری چیده شوند که **حتی رفتار و ارتباطات مشکوک خودِ ویندوز را هم زیر ذره‌بین ببرند و کنترل کنند.**

- به نظر من در مواردی نظیر آنتی‌ویروس، فایروال، و یا WAF نمی‌توانیم با محصولات خارجی رقابت کنیم. چون این شرکت‌های داخلی partnership ندارند، در نتیجه دسترسی مثلا به کرنل ندارند و در نتیجه بعضا کیفیت مناسب هم نمی‌توانند داشته باشند. از بالا که نگاه می‌کنم واقعا فایروال‌های بومی اصلا نمی‌کشند. یا مثلا متوجه نمی‌شوم که اگر ما داریم ویندوز استفاده می‌کنیم دیگر این‌که آنتی‌ویروس خارجی استفاده نکنیم، چه معنایی دارد.

بخشی از گفت و گوی یکی از شرکتهای خصوصی که قطعا می شناسید!



محتوای درس

- مولفه های یک XDR ایده آل بررسی می شود.

مراجع درس

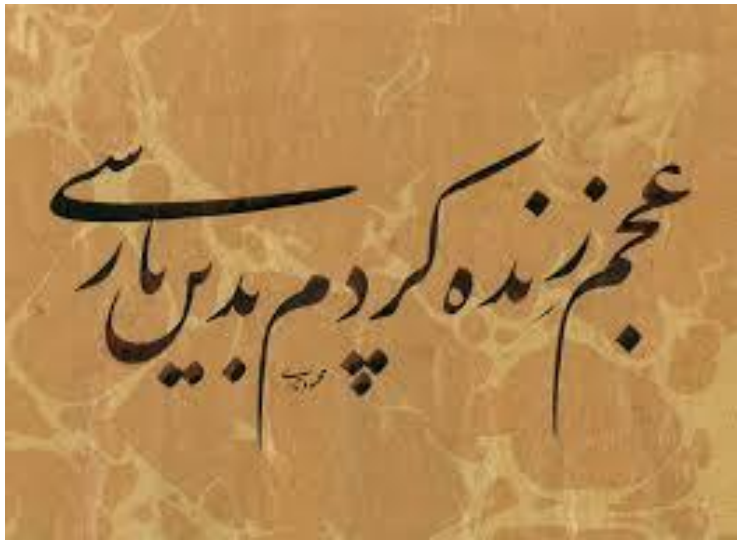
- با توجه به نیاز به به روز بودن در درس، کتاب واحدی شامل مطالب درس نیست.
- خواندنی ها سعی دارند مراجع نسبی در کنار اسلایدها برای هر جلسه فراهم کنند.
  - خواندنی های درس، مطالبی جهت فهم بهتر درس جلسه بعد، که خواندن آن اجباری است.
  - نیاز به جزوه نویسی یا یادداشت در کنار اسلایدها خواهید داشت.

هفته ای یک بار نه هفته اجباریه

- درس بالطبع حمله (نفوذ) محور است. پس خواندن به موقع مسیرهای نفوذ قبل از کلاس نیاز است .

نمره دهی

- حضور و فعالیت های کلاسی ۲۰٪
  - از سوال و جوابها وبحث های کلاسی در خصوص خواندنی ها و بحث روز نمره مرتبط با این بخش مشخص می شود
- تمرین ۲۰٪
- میان ترم ۱۵٪
- پروژه پایانی ۱۵٪
- پایان ترم ۳۰٪
- میان بر اضافه شدن مستقیم ۱ تا ۳ نمره ؟؟



زبان درس: قند پارسی

مجموعه واژه‌های مصوب

گروه واژه گزینی انجمن رمز ایران

(کارگروه واژه‌گزینی رمزشناسی فرهنگستان)

در فرهنگستان زبان و ادب فارسی

- https://isc.org.ir/files/site1/files/%D9%85%D8%AC%D9%85%D9%88%D8%B9%D9%87_%D9%88%D8%A7%DA%98%D9%87_%D9%87%D8%A7%DB%8C_%D9%85%D8%B5%D9%88%D8%A8_5-6.pdf

نمره دهی

- تکالیف هفتگی و مقاله‌خوانی ۱۵٪
- تمرین عملی ۲۰٪
- آزمون میان‌ترم۱۵٪
- پروژه ۲۰٪
- پایان ترم ۳۰٪
- میان بر اضافه شدن مستقیم ۱ تا ۳ نمره ؟؟
  - شرکت در CTFهایی متناسب با سطح شما به صورت فردی یا گروهی

ارتباط درسی

- در انتها و ابتدای هرکلاس فرصت رفع ابهامات شماست.
- با این حال اگر ابهامی باقی ماند یا هرمطلب دیگری در خصوص درس داشتید ایمیلی طرح کنید تا برای اولین فرصت قراری حضوری تنظیم شود.
- درباره بازخورد درباب کند یا تند بودن روند درس شک نکنید.

قواعد کلاس

- انجام تمرین ها گروهی امکان پذیر نیست.
- تمرینات تک نفره طراحی شده اند و نیاز به ارسال به صورتی اثبات پذیر برای انجام فردی هست.
- احتمال تحویل حضوری برای همه/برخی از تمرین ها هست
- انتخاب نماینده (برای اطلاع دادن دوطرفه در موارد نادر و رخدادهای ناگهانی)
  - اگر دارای معلولیت هستید، شرایط ویژه دارید، و.... اگر به بنده مرتبط است ایمیل بزنید.
  - اگر به بنده مرتبط نیست لطفا حتما با بخش مشاوره دانشجویی و معاون دانشجویی دانشکده در میان بگذارید

قواعد کلاس

- الزام رعایت شئونات اخلاقی و اسلامی در کلاس پیشفرض است.

خواندنی جلسه اول درس (جلسه بعدی)

- Krasznay, Csaba. "Case study: The notpetya campaign." *Információés kiberbiztonság* (2020): 485-499.

- Langner, R. (2013). To kill a centrifuge: A technical analysis of what stuxnet’s creators tried to achieve. *The Langner Group*, *37*.